

PROTECTING PEOPLE IN THE DIGITAL WORLD

In the event of a personal data breach, when and how should the affected individuals be notified? (art. 34 GDPR)

****For what purpose?****

To protect individuals from the consequences of a personal data breach.

****When?****

When there is a high risk to the rights and freedoms of individuals.

****To whom?****

To those natural persons who are at high risk due to the breach.

****Deadline?****

Without undue delay.

Before the consequences can affect individuals and with enough time for them to protect themselves.

****How?****

With a communication directed to each of the affected individuals.

For example, via email, SMS, instant messaging, or postal mail.

If it involves a disproportionate effort or it is not precisely known who may have been affected, a public announcement can be made that has the same effectiveness.

****Minimum content of the communication****

****Nature****

What has happened.

Describe whether it is a cyber incident, cyber attack, erroneous data transmission, loss of documentation/device, etc.

Which data has been affected.

Specify whether it concerns basic data, contact details, email, username and password, copies of ID or passport, contracts, invoices, profiles, locations, etc.

In what manner.

Specify whether it is due to unauthorized access, data extracted, disclosed to third parties or made public, altered, deleted, rendered unusable, or unavailable, etc.

****Measures****

Taken and proposed by the data controller to:

Resolve the breach.

Minimize the consequences for individuals.

****Consequences****

What impact it may have on individuals.

Diminishment of their fundamental rights, inability to exercise other rights, identity theft, inability to properly provide a service, fraud, discrimination, physical or psychological harm, among others.

****Aggravating circumstances.****

The recipient of their data is the person reported by you, the compromised password is used in other services, the data has been openly published on the internet, etc.

****Contact and identification****

Commercial or public identification of the data controller.

Contact details of the DPO or another means of contact for further information.

****To consider****

Do not use expressions that distort the message, such as "Your data is not at risk," "there is no risk," "your data has not been affected," "you can be calm, we have already reported it to the AEPD"....

Do not omit relevant details, so that individuals can adequately assess the risk based on their

particular circumstances.

It does not imply a single action or act. It can be executed in different actions depending on the information that the controller has regarding the magnitude of the breach and the affected individuals.

****It is not a communication to the affected individuals:****

Communicating a breach to a client entity or company.

Other notices or instructions for individuals that do not include the minimum content of art. 34.

Unjustified public announcement, without minimum content or that is not equally effective (websites or corporate portals not visited by the affected individuals or similar).

****Guide for the notification of personal data breaches****

AEPD_es

www.aepd.es

AEPD

@aepd.es